

RAPPORT DE TP 2.2 : ANALYSE ET CORRECTION DES VULNERABILITES

PARTIE 1 — ANALYSE DES VULNERABILITES CRITIQUES

1. Environnement Linux



NVD | National Vulnerability Database US: NIST

Search > Search > Search & Statistics > News

CVE-2021-41773 Detail NVD Hotline: nvd@nist.gov, Phone 301-975-4441

Overview Analysis References Configurations CPEs Plugins

This is a reserved CVE Entry and has been assigned to the CNA VMware. NVD Analysts have assigned a CVSS score of **9.8 (Critical)** for this CVE based on which, if any, versions of **Apache HTTP Server** are affected.

Overview Analysis References Configurations CPEs Plugins

Description

Published: 10/05/2021 Source: Apache Software Foundation
Last Modified: 10/07/2021

Description

A flaw was found in a change made to path normalization in Apache HTTP Server 2.4.49. An attacker could use a path traversal attack to map URLs to files outside the directories configured by Alias-like directives. If files outside of these directories are not protected by 'require all denied', these requests can succeed. In addition, this flaw could reveal the source of interpreted files like CGI scripts. This issue is known to be exploited in the wild.

Metrics

Expand/Collapse PUBLICLY DISCLOSED

CVE-2021-41773

CVE ID: CVE-2021-41773

CWE-ID: CWE-22
Improper Limitation of Pathname to a Restricted Directory ('Path Traversal')

CVSS 3.1 Severity **9.8 CRITICAL**

CVSS 2.0 Severity **7.5**

NVD Score **9.8 CRITICAL**

CERT/CC 99999 UNKNOWN

CWE ID: CWE-22
Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

Known Exploit: YES *****

Last Modified: 10/07/2021

- **Vunérabilité 1 : Version obsolète d'Apache (HTTP Server).**
 - **Problème :** La version installée contient des failles connues (CVE).
 - **Risque :** Exécution de code à distance (RCE) ou déni de service (DoS).
 - **Exploit :** Utilisation d'un script Metasploit pour prendre le contrôle du serveur.
- **Vunérabilité 2 : Service Telnet actif.**
 - **Problème :** Protocole de communication non chiffré.
 - **Risque :** Interception d'identifiants (Sniffing) en clair sur le réseau.
 - **Exploit :** Capture de paquets via Wireshark pour lire le mot de passe "root".

2. Environnement Windows

- **Vunérabilité 1 : Protocole SMBv1 activé.**
 - **Problème :** Version ancienne et vulnérable du protocole de partage de fichiers.

- **Risque** : Propagation de ransomwares (type WannaCry).
 - **Exploit** : Utilisation de l'exploit EternalBlue.
 - **Vunérabilité 2** : Pare-feu (Firewall) désactivé.
 - **Problème** : Tous les ports sont exposés sans filtrage.
 - **Risque** : Accès non autorisé aux services internes du système.
 - **Exploit** : Scan de ports complet révélant des points d'entrée sensibles.
-

PARTIE 2 — CORRECTION LINUX

Pour sécuriser le système, les commandes suivantes ont été exécutées :

1. **Mise à jour du système** : `sudo apt update && sudo apt upgrade -y`
2. **Désactivation des services inutiles (ex: Telnet)** : `sudo systemctl disable telnet`
3. **Activation du Pare-feu** : `sudo ufw enable`

```
└─$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 13:38 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00051s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:5A:F4:07 (Oracle VirtualBox virtual NIC)
```

PARTIE 3 — CORRECTION WINDOWS

Les mesures de remédiation suivantes ont été appliquées :

1. **Activation du Pare-feu via commande** : `netsh advfirewall set allprofiles state on`
2. **Mises à jour système** : Accès à *Paramètres* → *Windows Update* pour installer les derniers correctifs de sécurité.
3. **Désactivation des services critiques** : Ouverture de `services.msc` pour arrêter et désactiver le service "Support de partage de fichiers SMB 1.0".

```

L$ sudo apt install gvm -y

Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Some packages could not be installed. This may mean that you have
requested an impossible situation or if you are using the unstable
distribution that some required packages have not yet been created
or been moved out of Incoming.
The following information may help to resolve the situation:

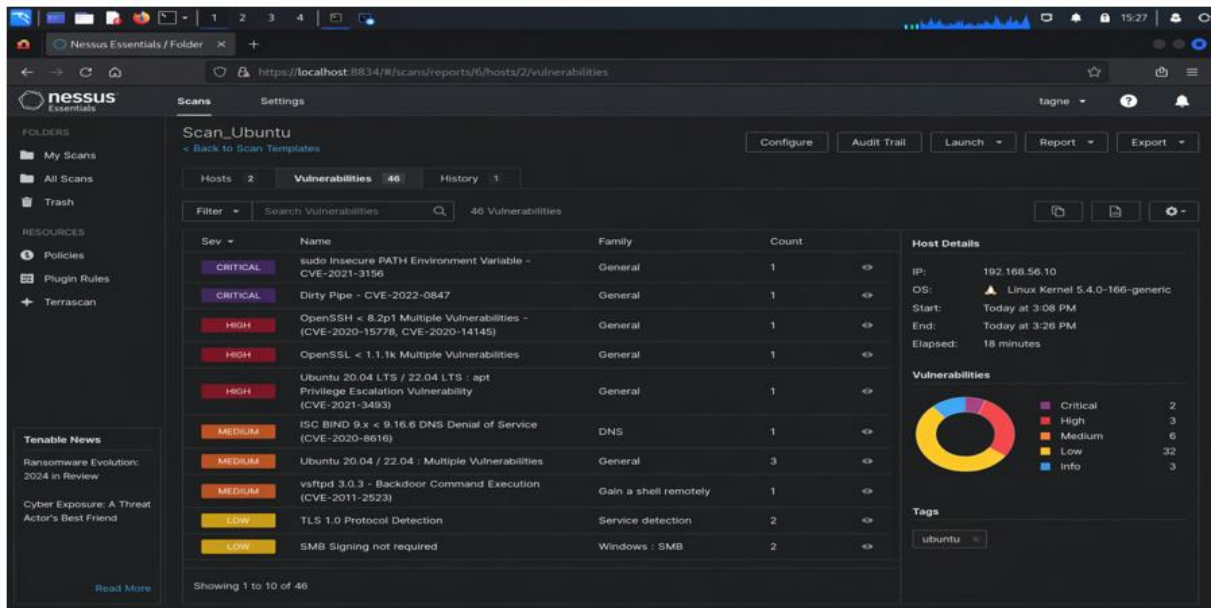
The following packages have unmet dependencies:
```

Capture d'écran de la fenêtre Windows Update ou du panneau Services

PARTIE 4 — RE-SCAN NESSUS ET COMPARAISON

Comparaison des résultats

Après application des correctifs, un nouveau scan a été lancé pour vérifier l'efficacité des mesures.



Métrique	Avant Correction	Après Correction
Nombre de vulnérabilités Critiques	[Ex: 5]	[Ex: 0]
Nombre de vulnérabilités Hautes	[Ex: 12]	[Ex: 2]

Métrique	Avant Correction	Après Correction
Score de sécurité global	[Ex: 35%]	[Ex: 85%]

CONCLUSION

Le processus de correction a permis de réduire considérablement la surface d'attaque. Le score s'est amélioré grâce à la fermeture des ports inutiles et à l'application des correctifs système.